

Экспресс-аудит безопасности dr-knyazkin.ru

Дата: 15 апреля 2026 • Формат: пассивный аудит публичных данных

Итог для руководителя

Критичного инцидента не выявлено, но обнаружены 4 сильные зоны для апсейла: email-защита домена, security headers, supply-chain фронтенда, комплаенс формы/политики.

Приоритетные проблемы

P1 Email-защита домена не настроена

- **Факт:** не найдены SPF/DMARC/DKIM (и MTA-STS/TLS-RPT).
- **Риск:** подмена писем от имени клиники, фишинг, репутационные потери.
- **Действие:** SPF + DMARC + DKIM, затем MTA-STS/TLS-RPT.

P1 Неполный baseline security headers

- **Факт:** отсутствуют HSTS, CSP, XCTO, Referrer-Policy, Permissions-Policy.
- **Риск:** повышенная поверхность атак и слабый baseline hardening.
- **Действие:** внедрить стандартный набор заголовков, затем ужесточить CSP.

P1 Supply-chain риск фронтенда

- **Факт:** 25 внешних скриптов без SRI, найден jQuery 1.10.2.
- **Риск:** риск компрометации через сторонние JS-зависимости.
- **Действие:** обновить jQuery, включить SRI, сократить внешние зависимости.

P2 Комплаенс формы/политики

- **Факт:** на формах есть ссылка на /politika, но URL политики в публичной проверке отвечает 403.
- **Риск:** юридические вопросы по прозрачности обработки ПДн.

- **Действие:** обеспечить публичную доступность политики и явную связку с формами.

P2 Поведение www-хоста

- **Факт:** `https://www.dr-knyazkin.ru/` отдавал 403, при этом `http://www...` ведёт 301 на канонический хост.
- **Риск:** непредсказуемость для части пользователей/ботов/мониторингов.
- **Действие:** унифицировать `www/non-www` сценарий.

Что уже в норме

OK Рабочая база есть

- TLS-сертификат валиден.
- HTTP → HTTPS редирект на основном хосте настроен.
- Mixed content на главной не найден.
- `robots.txt` и `sitemap.xml` доступны.

Предложение на демо

- План фиксов на 14/30 дней с приоритетом по бизнес-рisku.
- Быстрые победы без тяжёлого рефакторинга.
- Переход к целевому baseline безопасности для клиники.

Ограничение: часть URL под антибот-защитой (403/429), поэтому часть проверок требует валидации на демо с доступом к инфраструктуре.